

Article

Quishing: A Sociotechnical Framework for Understanding QR-Code Phishing Risks and User-Centered Protection Strategies

Pedro-David Filio-Aguilar ^{1,*} , Rubén Mil-Martínez ²  and Lourdes López-García ³

¹ Sección de Maestría en Ciberseguridad y Ciberdefensa, Escuela Militar de Ingeniería, Universidad del Ejército, Fuerza Aérea y Guardia Nacional, Av. Industria Militar No. 261, Col. Lomas de San Isidro, Naucalpan de Juárez 53960, State of Mexico, Mexico

² Departamento de Ingeniería Industrial, Escuela Militar de Ingeniería, Universidad del Ejército, Fuerza Aérea y Guardia Nacional, Av. Industria Militar No. 261, Col. Lomas de San Isidro, Naucalpan de Juárez 53960, State of Mexico, Mexico; rbnmar2802@emings.onmicrosoft.com

³ Tecnológico Nacional de México Campus Querétaro, Av. Tecnológico S/N, Centro Histórico, Santiago de Querétaro 76000, Querétaro, Mexico; lourdes.lg@queretaro.tecnm.mx

* Correspondence: pfilio@emings.onmicrosoft.com

Abstract

The widespread use of Quick Response (QR) codes increases exposure to QR-code-based phishing, or quishing. This study examines the mechanisms, user behaviors, and contextual conditions that shape QR-mediated risk from a sociotechnical perspective. A structured literature review and narrative synthesis were conducted using four documented search strings. Following deduplication, screening, retrieval, and full-text assessment, 27 studies were included from 71 identified records. Two reviewers independently evaluated methodological quality using six criteria. The corpus comprised 16 technical-detection studies, five user-centered or behavioral studies, two attack demonstrations or simulations, and four reviews or preventive frameworks. The mean consensus quality score was 10.04 out of 12; 19 studies were classified as high quality and eight as moderate quality. The synthesis indicates that quishing exploits the interaction of contextual legitimacy, routine scanning, limited destination visibility, and insufficient verification before navigation or disclosure of sensitive information. These findings informed an attack lifecycle, a sociotechnical model, a user security decision flow, a risk–protection mapping, and multilevel recommendations. These literature-derived artifacts are conceptual and heuristic rather than empirically validated. Effective mitigation therefore requires QR-specific verification mechanisms combined with behavioral and technical safeguards for users, interfaces, organizations, and platforms, followed by expert, usability, and experimental validation.



Academic Editors: Jun Feng and Changqing Luo

Received: 19 June 2026

Revised: 30 July 2026

Accepted: 5 August 2026

Published: 8 August 2026

Copyright: © 2026 by the authors. Licensee MDPI, Basel, Switzerland. This article is an open access article distributed under the terms and conditions of the [Creative Commons Attribution \(CC BY\)](https://creativecommons.org/licenses/by/4.0/) license.

Keywords: quishing; QR code phishing; QR code security; phishing detection; social engineering; cyber threats; cybersecurity awareness; human-centered security

1. Introduction

Quick Response (QR) codes provide a low-cost bridge between physical objects and digital services. Their use in electronic payments, retail, marketing, government services, education, and data collection has normalized scanning as a routine interaction [1–7]. This convenience also changes the security context: a user can reach a website, application, authentication flow, or payment interface by decoding a visual symbol rather than by first inspecting a conventional hyperlink.

Quishing is a QR-code-mediated form of phishing in which an encoded destination directs a user to a fraudulent or malicious resource [8–12]. Although its downstream objectives commonly resemble those of conventional phishing, the QR channel modifies both delivery and verification. The destination is not directly readable before decoding; the code may inherit legitimacy from a physical object, branded document, payment prompt, or institutional environment; a legitimate code may be replaced or covered by a malicious overlay; and the interaction often continues on a mobile interface with restricted visibility of domains and redirects [8,9,11–13]. After navigation, attackers may still rely on familiar phishing mechanisms such as impersonation, urgency, deceptive login or payment pages, credential harvesting, and malicious downloads.

Research on quishing has developed primarily along technical lines. Existing studies have examined structural characteristics of QR symbols, machine learning and deep learning classification, Uniform Resource Locator (URL) and domain analysis, multimodal detection, secure-code generation, cryptographic verification, blockchain-supported authentication, and broader artificial intelligence (AI)-enhanced security frameworks [14–20]. Attack demonstrations and security reviews have also documented how QR codes can conceal malicious destinations, bypass link-oriented controls, and transfer the interaction across physical, email, browser, and mobile channels [10–12]. These contributions expand the defensive repertoire, but technical performance measured on a dataset or prototype does not by itself establish that users will receive understandable, timely, and actionable protection during realistic interactions.

A smaller body of work has examined user susceptibility, security behavior, awareness, and naturalistic interaction with malicious QR codes [8,9,13,21]. The broader phishing literature indicates that attention, prior knowledge, habitual media use, social context, and the processing of familiar or authoritative cues can influence security decisions [22–24]. Usable-security research likewise cautions against treating the user as the sole point of failure when interfaces conceal relevant information or impose impractical verification demands [25]. Cognitive factors such as authority, familiarity, normality, urgency, optimism, social proof, and habituation may therefore help interpret quishing behavior; however, these variables have not been measured consistently in the QR-specific evidence base and should not be treated as established causal determinants.

Recent usable-security research, discussed in Section 4.3, also underscores the need to design and evaluate warnings, nudges, and awareness interventions as decision-support mechanisms that can be assessed through observable behavior rather than through knowledge or stated intentions alone.

The literature consequently remains fragmented across technical detection, attack demonstrations, behavioral studies, and conceptual security frameworks. Relatively few analyses connect the QR-specific properties of destination opacity, physical-to-digital trust transfer, code substitution, and mobile verification constraints with the user decision process and the controls available to interfaces, organizations, platforms, and security infrastructure. In addition, QR-specific safeguards are often presented together with general cybersecurity practices without clarifying the stage of the interaction or the actor responsible for implementation. A sociotechnical synthesis is therefore needed to explain how these elements interact and to distinguish evidence-supported findings from literature-derived proposals.

Accordingly, this study was conducted as a conceptual investigation informed by a structured, targeted literature review and a narrative thematic synthesis. Its objective is to characterize the mechanisms and conditions associated with QR-code phishing and to organize the available evidence into a user-centered, multi-level protection perspective.

The study does not estimate the prevalence of quishing, calculate pooled effect sizes, or empirically test the effectiveness of the proposed interventions.

Specifically, this study makes the following contributions:

1. A structured synthesis of the quishing-specific evidence, including a distinction between QR-mediated mechanisms and deceptive techniques shared with conventional phishing.
2. A literature-derived operational sequence and sociotechnical model linking QR-code delivery, contextual legitimacy, routine scanning, constrained verification, and subsequent exploitation.
3. A heuristic user security decision flow and an integrated mapping of attack stages, risk conditions, responsible actors, and potential intervention points.
4. A multi-level Decalogue of Protection organized by responsible actor, interaction timing, and whether each measure is QR-specific or part of broader defense-in-depth.

The conceptual models, decision flow, and protection recommendations are literature-derived heuristic artifacts rather than predictive models or empirically validated guarantees of risk reduction. Their purpose is to consolidate the available evidence, identify plausible interruption points, and define components that can be evaluated through expert review, usability testing, controlled experiments, and naturalistic studies.

The remainder of this paper is organized as follows. Section 2 describes the search, selection, appraisal, and synthesis procedures. Section 3 reports the evidence profile, recurrent mechanisms, conceptual outputs, and revised protection matrix. Section 4 interprets the findings in relation to technical defenses, human factors, usable security, and existing behavioral models. Section 5 presents the conclusions and priorities for empirical validation.

2. Methodology

This study was conducted as a conceptual investigation informed by a structured, targeted literature review and a narrative thematic synthesis. The purpose was to integrate the technical, behavioral, and sociotechnical evidence available on QR-code-based phishing and to use that evidence to develop literature-derived models and protection recommendations. The study was not designed to estimate the prevalence of quishing, calculate pooled effect sizes, or test the effectiveness of the proposed interventions. The reporting of the search and study-selection process was informed by applicable elements the Preferred Reporting Items for Systematic Reviews and Meta-Analyses extension for Scoping Reviews of (PRISMA-ScR) and the PRISMA extension for Literature Searches PRISMA-S [26,27], used here as transparency guidelines rather than as a claim that the study constitutes an exhaustive systematic review.

2.1. Information Source and Search Strategy

The formal search was conducted on 20 July 2026 in Google Scholar using Publish or Perish. This source was selected because quishing research is distributed across cybersecurity, human–computer interaction, mobile computing, communications, payment security, and recent conference or preprint venues. Bibliographic records were subsequently verified through sources including IEEE Xplore, arXiv, Crossref, publisher platforms, conference proceedings, and institutional repositories. The search covered publications dated from 2010 to 2026.

Four independent title-field queries were executed to account for the inconsistent terminology used in this emerging field: quishing ($n = 17$), “QR phishing” ($n = 24$), “QR code phishing” ($n = 27$) and “QR-based phishing” ($n = 3$). The searches returned 71 records before duplicate removal. All results were exported in comma-separated values (CSV) format, and the available title, authors, year, source, abstract, digital object identifier (DOI),

and access URL were retained. Bibliographic information was checked against DOI records, publisher pages, conference proceedings, institutional repositories, or preprint servers when necessary.

2.2. Eligibility Criteria and Study Selection

A record was eligible for the primary corpus when it: (1) examined a QR code as a vector for phishing, fraudulent redirection, credential theft, payment fraud, malware delivery, impersonation, or a closely related malicious action; (2) addressed an aspect of attack execution, detection, user susceptibility, verification, awareness, interface design, or mitigation; (3) was published as a journal article, conference paper, scholarly book chapter, or academic preprint; (4) was written in English or Spanish; (5) fell within the 2010–2026 period; and (6) had a retrievable full text containing sufficient information to determine its contribution.

Records were excluded when they discussed QR applications without a relevant security component; used QR codes solely as a defensive authentication mechanism against conventional phishing without examining QR-mediated attacks; were news items, commercial announcements, professional articles, undergraduate theses, repository assignments, or other non-eligible document types; were written in another language; contained insufficient bibliographic or methodological information; duplicated another record or represented an earlier version; could not be retrieved in full text; or corresponded to the authors' own manuscript. Preprints were retained when they met the substantive criteria, but their non-peer-reviewed status was recorded and considered during interpretation.

Duplicate removal was performed through exact DOI matching, normalized-title comparison, and manual review of similar records and publication versions. Nineteen duplicates were removed, leaving 52 unique records. Two reviewers (P.-D.F.-A. and L.L.-G.) independently screened the titles and abstracts and classified each record as included, excluded, or uncertain. Fifteen records were excluded at this stage. Full-text retrieval was attempted for the remaining 37 reports; 10 were not available for full-text assessment during the review period. Both reviewers independently assessed the 27 available full-text reports, all of which met the eligibility criteria. Disagreements at any stage were resolved through discussion and consensus. The resulting flow—71 records identified, 19 duplicates removed, 52 records screened, 15 excluded, 37 reports sought, 10 not retrieved, and 27 studies included—is summarized in Figure 1, which presents the PRISMA-style flow diagram. Record-level screening decisions, retrieval status, and reasons for exclusion are documented in Supplementary File S1.

Foundational studies on conventional phishing, usable security, information processing, automaticity, and contextual trust were selected separately for theoretical comparison in the Discussion [22–25,28–31]. These sources were not counted as quishing-specific studies and were excluded from the PRISMA flow and descriptive characterization of the primary corpus.

2.3. Data Extraction and Methodological Quality Appraisal

A structured matrix was used to extract the following information from each included study: bibliographic and publication status; objective; research design; participant sample, dataset, or evidence base; attack or interaction channel; QR-specific mechanism; behavioral or contextual factors; technical approach; proposed mitigation; validation procedure; principal findings; limitations; and evidentiary category. The two reviewers completed the extraction independently and reconciled differences by returning to the full text.

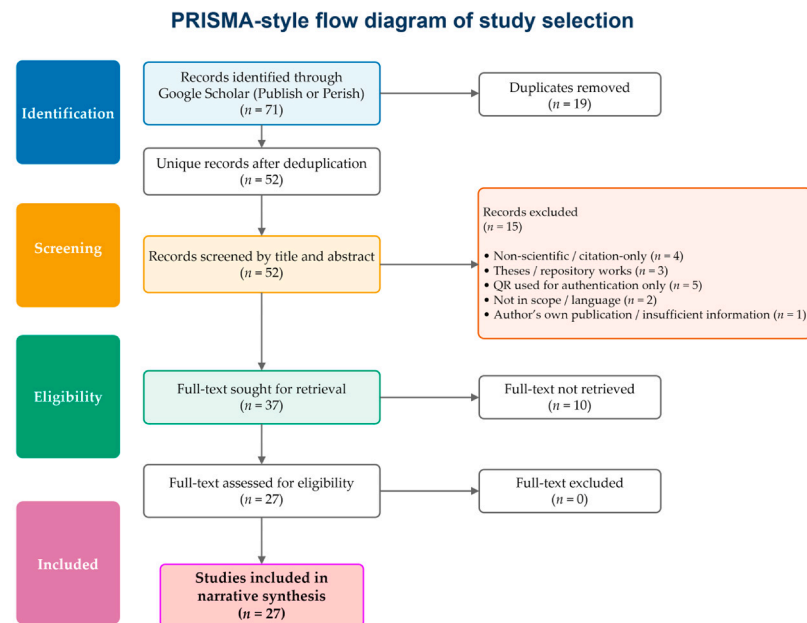


Figure 1. Preferred Reporting Items for Systematic Reviews and Meta-Analyses (PRISMA)-style flow diagram of record identification, deduplication, screening, full-text retrieval, and final inclusion. Colors identify the study-selection stages: blue, identification; orange, screening; green, eligibility; and pink, inclusion. The pale-orange box lists records excluded during screening. The symbol n denotes the number of records or reports.

Methodological quality was assessed independently by both reviewers using six criteria: clarity of the objective or research question (Q1); sufficiency of the method description (Q2); description of the sample, participants, dataset, or evidence base (Q3); appropriateness of the analysis or validation procedure (Q4); correspondence between findings and conclusions (Q5); and recognition of limitations or threats to validity (Q6). Each criterion was scored as 0 (absent or inadequate), 1 (partially addressed), or 2 (clearly addressed). Total scores of 10–12 were classified as high quality, 7–9 as moderate quality, and 0–6 as limited quality. Exact percentage agreement and Cohen's kappa were calculated before consensus. Quality scores were not used as automatic exclusion criteria; instead, they were used to weigh the interpretation of the evidence and to distinguish well-supported findings from preliminary or conceptual contributions.

2.4. Narrative Thematic Synthesis

A meta-analysis was not appropriate because the studies differed substantially in design, samples, datasets, validation procedures, and outcome measures. The evidence was therefore integrated through a narrative thematic synthesis. Initial coding focused on four domains directly aligned with the study objectives and research questions: attack mechanisms and distribution channels; technical detection and verification; human and contextual factors; and mitigation measures. Inductive coding was then used to identify recurring subthemes, including physical substitution of QR codes, opacity of the encoded destination, transfer of trust from the surrounding environment, routine scanning, restricted mobile-screen cues, and credential, payment, or installation requests after redirection.

During synthesis, QR-specific properties were distinguished from mechanisms shared with conventional phishing. The analysis also differentiated observed behavior from self-reported intentions, controlled technical evaluations from real-world or naturalistic studies, and empirically tested controls from conceptual proposals. Descriptive counts were used only to characterize the corpus and the recurrence of themes [22–25,28–31]; they were not interpreted as effect estimates or causal evidence.

2.5. Development and Status of the Conceptual Outputs

The conceptual outputs were developed after the thematic synthesis. Recurrent findings were mapped onto the stages of a quishing interaction: preparation and placement of the QR code, user exposure and scanning, disclosure and assessment of the destination, interaction with the resulting resource, and potential compromise. This mapping supported the refinement of the attack lifecycle, the sociotechnical model, the user security decision flow, and the integrated framework linking risk conditions with possible intervention points.

The protection guidelines were derived from the same evidence and organized by responsible actor and intervention point. The models and recommendations are literature-derived heuristics, not empirically validated as an integrated intervention in this study. They should therefore be interpreted as an analytical synthesis and a basis for future evaluation, not as predictive models or proven guarantees of risk reduction.

3. Results

The results are organized around the study-selection process, the composition and methodological quality of the evidence base, the recurrent technical and human mechanisms identified across the corpus, and the conceptual artifacts derived from the synthesis. The findings reported below distinguish evidence obtained directly from QR-code phishing studies from interpretations supported by the broader phishing and usable-security literature.

3.1. Study Selection

The four Google Scholar searches retrieved 71 records. After 19 duplicates were removed through DOI matching, normalized-title comparison, and manual reconciliation of variant records, 52 unique records remained for title-and-abstract screening. Fifteen records were excluded because they did not meet the eligibility criteria. The principal reasons were non-scholarly publication type, use of QR codes solely as a defensive authentication mechanism, language restrictions, insufficient bibliographic or methodological information, and identification of the authors' own manuscript.

Full-text retrieval was attempted for the remaining 37 records. Ten reports could not be recovered within the review period. The other 27 reports were assessed independently by both reviewers and met the final eligibility criteria; no additional exclusions were recorded after full-text assessment. Accordingly, 27 studies were included in the primary synthesis. The complete selection process is shown in Figure 1, while study-level decisions and exclusion reasons are reported in Supplementary File S1.

3.2. Evidence Profile and Methodological Quality

The included studies were published between 2013 and 2026. The temporal distribution was strongly concentrated in recent years: 19 of the 27 studies (70.4%) appeared from 2024 onward. Five studies (18.5%) were available as preprints at the search cut-off date, whereas the remaining 22 were published as journal articles, conference papers, or scholarly book chapters.

For descriptive purposes, each study was assigned to the evidence strand that best represented its principal contribution. Sixteen studies (59.3%) focused primarily on technical detection, prevention, authentication, integrity verification, network interception, or dataset development. Five studies (18.5%) examined user susceptibility, security behavior, awareness, or naturalistic interaction. Two studies (7.4%) centered on attack implementation or simulation, and four studies (14.8%) contributed reviews or preventive frameworks.

This distribution shows that the field is currently dominated by technical proposals, while direct empirical evidence concerning user decision-making remains comparatively limited.

Table 1 presents representative publications selected to reflect the four evidence strands, the temporal development of the field, and the diversity of methods used. It is not intended to reproduce the entire corpus. The complete extraction matrix for all 27 studies is provided in Supplementary File S1 [8,9,12,13,17,18,20,21,32–50].

Table 1. Comparative synthesis of representative quishing studies.

Representative Study	Evidence Strand/Method	Main Contribution	Main Limitation
[8] QRishing	User susceptibility; controlled smartphone experiment	Established that concealed destinations and limited verification make users susceptible to QR phishing.	Controlled setting; layered technical and organizational controls were not evaluated.
[9] Phishing with Malicious QR Codes	User behavior; field-oriented usable-security study	Linked QR interaction and credential disclosure to convenience, awareness, and verification behavior.	Scenario- and sample-specific; broader naturalistic replication is needed.
[35] Internet-banking quishing simulation	Attack demonstration; attack-tree and time-based analysis	Modeled and demonstrated a QR-phishing scenario targeting Indonesian internet banking using an attack tree and time-based metrics.	Scenario-specific implementation; limited generalizability and no real-user mitigation-effectiveness evaluation.
[43] QR-scanner phishing simulation	Attack demonstration; controlled QR-scanner simulation	Demonstrated vulnerabilities in QR scanning and reading mechanisms that may lead to cookie and organizational-data exposure.	Controlled technical scenario; no real-user or mitigation-effectiveness evaluation.
[17] Machine learning quishing detection	Technical detection; QR-code analysis and machine learning	Evaluated the feasibility of detecting quishing through machine learning analysis of QR codes.	Preprint evidence; external validation and dataset generalizability remain limited.
[18] B-PhishQR	Technical prevention; blockchain verification architecture	Shifted protection toward QR provenance, authenticity, validation, and revocation.	Complexity, scalability, governance, and adoption may constrain deployment.
[12] Quishing mitigation	Review/preventive framework; conceptual analysis	Consolidated quishing risks and practical user and technical mitigation measures.	Recommendations were not validated as an integrated intervention.
[33] Deep learning quishing review	Systematic literature review; deep learning approaches	Synthesized emerging attack vectors, multimodal feature fusion, and open research challenges in quishing detection.	Review-based evidence; conclusions depend on the scope and quality of the included studies.

This table is a purposive representative synthesis and does not reproduce the complete corpus. Study-level bibliographic, selection, extraction, methodological-quality, and traceability data for all 27 included publications are provided in Supplementary File S1.

The methodological appraisal produced a mean consensus score of 10.04 out of 12, with individual scores ranging from 7 to 12. Nineteen studies (70.4%) were classified as having high methodological quality and eight (29.6%) as having moderate quality; none fell within the limited-evidence category. Across the 162 criterion-level ratings, the reviewers reached exact agreement in 88.3% of cases. The overall unweighted Cohen's kappa was 0.733. Agreement was highest for the presence of a clearly defined objective (100%) and lowest for the extent to which conclusions were supported by the reported results (77.8%).

The reviewers assigned identical total scores to 14 studies; the other 13 differed by only one point before consensus.

3.3. QR-Specific Attack Mechanisms and Operational Sequence

The synthesis identified four recurring characteristics that distinguish quishing from conventional hyperlink-based phishing. First, the encoded destination is not directly readable by the user before decoding, which delays inspection of the target address. Second, a QR code can inherit legitimacy from its physical or digital placement; a malicious sticker, replaced code, branded poster, invoice, email attachment, or payment prompt may therefore appear trustworthy before any digital verification occurs. Third, scanning frequently transfers the interaction from one channel to another, such as from a public sign, desktop email, or printed document to a mobile browser or payment application. This cross-channel transition can weaken continuity of security cues and limit the visibility of the destination. Fourth, some scanners and application flows encourage immediate navigation, authentication, payment, permission granting, or software installation after decoding.

These QR-specific properties generally precede, rather than replace, familiar phishing techniques. Once the user reaches the destination, the attacker may still rely on domain impersonation, fraudulent login interfaces, payment manipulation, urgency, or malicious downloads. The distinction is important: the QR code primarily conceals and transports the destination, while the subsequent deception may use mechanisms shared with other phishing channels.

Across the corpus, these mechanisms were synthesized into a seven-stage operational sequence: (1) preparation of the malicious QR code or destination; (2) distribution through a physical or digital channel; (3) user exposure and scanning; (4) decoding and navigation; (5) presentation of a fraudulent landing page or resource; (6) a requested action, such as credential entry, payment, installation, or authorization; and (7) potential impact, including credential theft, payment fraud, malware delivery, session abuse, or data disclosure. Figure 2 presents this sequence as a literature-derived analytical representation rather than as a probabilistic or empirically validated attack model.



Figure 2. Literature-derived operational sequence of a quishing attack, from preparation and distribution to user interaction and exploitation.

3.4. Human, Contextual, and Cognitive Factors

Although the behavioral evidence base was smaller than the technical literature, the user-oriented studies converged on three recurrent conditions. The first was contextual trust transfer: users often interpret the apparent legitimacy of the surrounding environment, organization, brand, or service as indirect evidence that the QR code is safe. The second was automaticity. Scanning has become a rapid, familiar, and convenience-oriented action, which may be performed with limited deliberation when the perceived risk is low. The third was constrained verification. The destination is unavailable to unaided visual inspection

before decoding, and the subsequent mobile interface may provide limited space or time to examine domains, redirects, certificate information, or requested actions.

The broader theoretical corpus helped us to interpret these patterns in terms of peripheral information processing, familiarity and authority heuristics, habitual behavior, and reduced suspicion. However, most QR-specific studies did not directly measure individual cognitive biases. These concepts should therefore be understood as explanatory interpretations of observed patterns, not as independently validated causal variables within the present corpus. Urgency, social proof, and perceived convenience appeared in several scenarios, but they were less consistently operationalized than contextual trust, automaticity, and verification constraints.

The convergence of these findings produced the sociotechnical heuristic shown in Figure 3. It represents quishing risk as the interaction of a trusted context, a routine or low-friction user action, and insufficiently visible or usable verification mechanisms. The model organizes the evidence but does not estimate the probability that a particular user will be victimized.

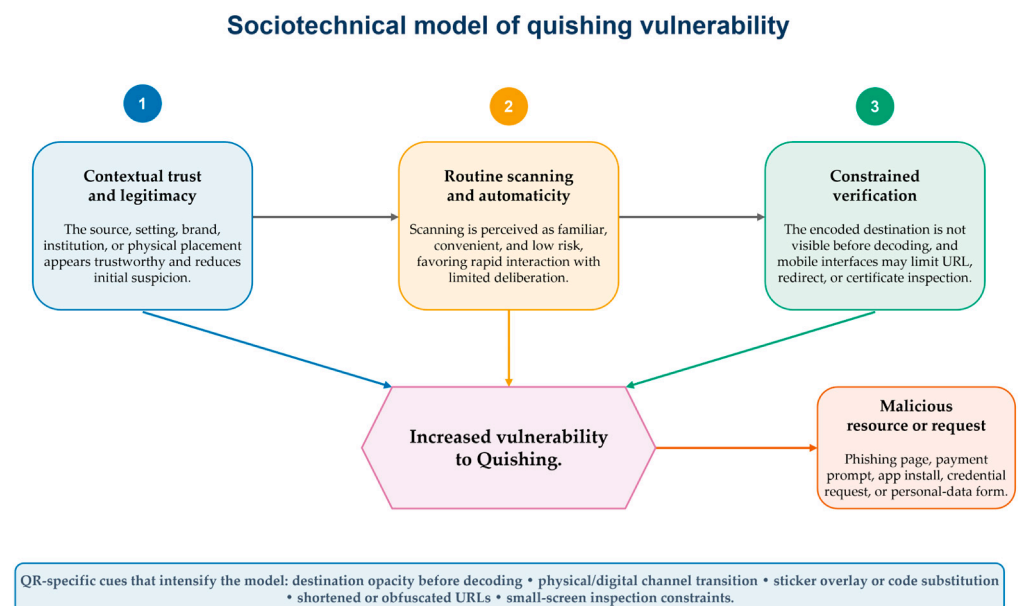


Figure 3. Literature-derived sociotechnical model linking contextual trust, routine scanning behavior, and constrained verification. Note: This model is a conceptual synthesis derived from the reviewed literature. It organizes plausible vulnerability conditions and should not be interpreted as an empirically validated causal model. Colors distinguish contextual trust (blue), routine scanning (orange), constrained verification (green), the combined vulnerability state (pink), and the malicious resource or request (orange-red). Abbreviations: QR, Quick Response; URL, Uniform Resource Locator.

3.5. Defensive Approaches and Remaining Coverage Gaps

The countermeasures identified in the corpus clustered into four families. The first comprised automated detection methods, including structural analysis of QR symbols, URL-based classification, deep learning, multimodal feature fusion, multilingual embeddings, and combined static and dynamic inspection. The second comprised authenticity and integrity mechanisms, including cryptographic signatures, hash-based message authentication code HMAC-based validation, tokenization, secure QR generation, and blockchain-supported verification. The third involved intervention at the network, scanner, browser, or mobile-application layer, with the objective of decoding and assessing the destination before navigation or detecting suspicious behavior within WebView-based interactions. The fourth combined user-centered and organizational measures, such as destination preview,

independent navigation to official services, contextual warnings, authenticated placement of institutional codes, reporting procedures, and awareness interventions.

No single control family covered the complete attack sequence. Image or structure-based detection may identify manipulated codes but cannot necessarily determine whether a newly registered destination is fraudulent. URL classifiers may operate only after decoding and can be affected by redirects, shortening services, compromised legitimate domains, or rapidly changing infrastructure. Cryptographic and blockchain proposals can strengthen authenticity, but their effectiveness depends on deployment, key management, governance, interoperability, and adoption. User education can improve deliberate verification, yet it remains vulnerable to habituation and cannot compensate for interfaces that suppress or obscure relevant security information.

Several limitations recurred across technical studies: dependence on study-specific or synthetic datasets, limited external validation, controlled experimental settings, incomplete reporting of false positives and operational latency, and scarce evaluation across different scanners, mobile platforms, and real-world deployment contexts. The behavioral literature was constrained by the small number of direct user studies, context-specific samples, short observation periods, and limited experimental evaluation of warnings or training interventions. The presence of five preprints further supports a cautious interpretation of the newest technical claims.

3.6. Conceptual Integration and Multi-Level Protection Strategy

The findings were integrated into a literature-derived user security decision flow containing five practical checkpoints. Before scanning, the user or responsible organization should assess the source, placement, and physical integrity of the code. After decoding, the destination should be displayed without automatic navigation. Before access, the complete domain, subdomains, redirects, and shortened addresses should be examined. At the destination, unexpected requests for credentials, payments, application installation, permissions, or authentication approval should be treated as high-risk signals. When the expected service is sensitive, the safer alternative is to close the QR-mediated path and reach the official service manually or through its verified application. Suspicious codes or interactions should be aborted and reported. Hypertext Transfer Protocol Secure (HTTPS) and certificate validity are intentionally not used as stand-alone decision criteria in the proposed flow. Although they indicate that the connection is encrypted, they do not establish that the destination belongs to the expected service, because fraudulent websites may also use valid certificates. The resulting sequence is presented in Figure 4.

Figure 5 integrates the operational sequence, the sociotechnical conditions, the user decision points, and the available defensive controls. It maps each control to the stage at which it can interrupt the attack and to the actor primarily responsible for implementation: the user, interface or platform provider, organization, or security infrastructure. This mapping also distinguishes QR-specific safeguards from general cybersecurity practices.

The resulting protection strategy is summarized in Table 2. The original user-only decalogue was reorganized by responsible actor, intervention timing, and scope because the evidence indicates that responsibility cannot be assigned exclusively to the individual who scans the code. To ensure consistent classification, scope was normalized as QR-specific, defense-in-depth, or QR-specific + defense-in-depth. Several measures require secure interface design, institutional control of published QR codes, platform-level inspection, or post-incident response.

Proposed user security decision flow for QR-code interactions

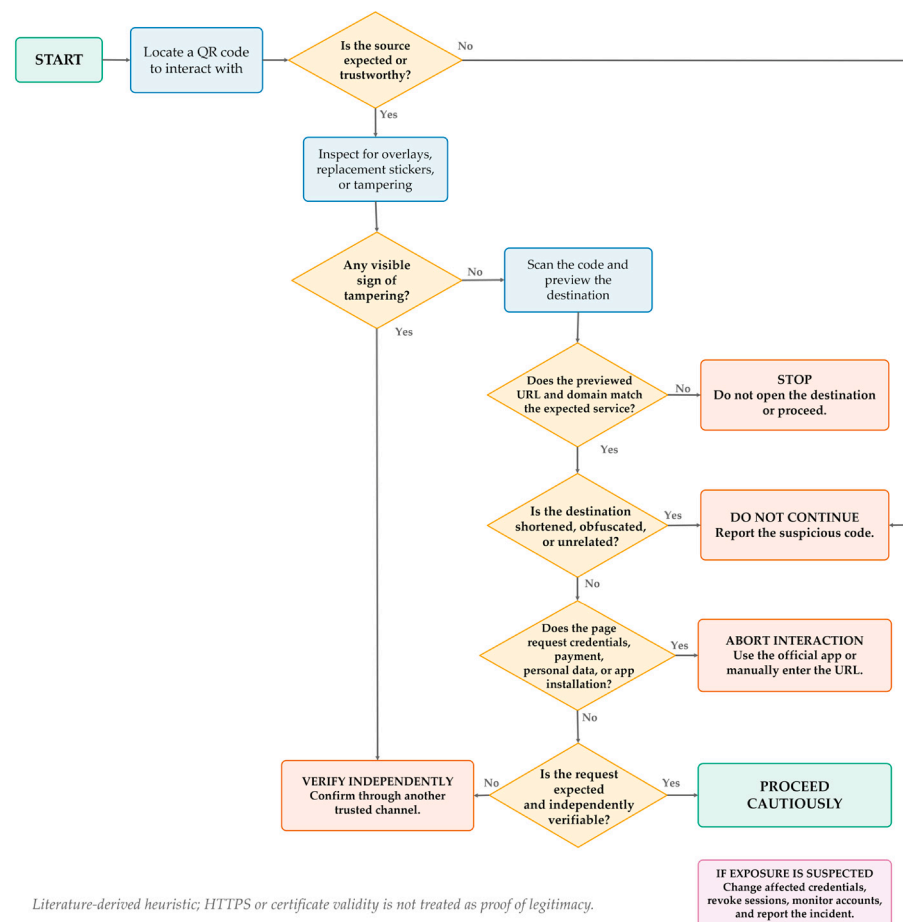


Figure 4. Literature-derived heuristic user-security decision flow for assessing QR-code source and physical integrity, previewing the destination, validating the expected domain, evaluating sensitive or unexpected requests, and selecting an appropriate response. HTTPS or certificate validity is not treated as proof of legitimacy, and the proposed flow has not yet been empirically validated. Colors identify process actions (blue), decision points (yellow), stop or independent-verification responses (orange), cautious continuation (green), and post-exposure response (pink). Abbreviations: HTTPS, Hypertext Transfer Protocol Secure; QR, Quick Response; URL, Uniform Resource Locator.

The decision flow, integrated framework, and protection matrix are literature-derived heuristic artifacts and were not empirically validated as a combined intervention in this study. They should therefore be interpreted as conceptual representations of plausible risk conditions and interruption points, rather than as evidence of intervention effectiveness or a statistically significant reduction in quishing victimization.

Overall, the evidence supports interpreting quishing as a sociotechnical threat whose effectiveness depends on the interaction of QR-specific opacity and channel transition, contextual legitimacy, user automaticity, and weaknesses in verification design. Technical literature provides an expanding set of detection and authentication mechanisms, but the comparatively limited behavioral evidence and the absence of end-to-end validation indicate that effective mitigation will require layered controls distributed across users, interfaces, organizations, and security infrastructure.

Conceptual mapping of quishing stages, risks, actors, and controls

Interaction stage	Principal risk	Primary actor(s)	Representative control(s)
Pre-scan exposure	Physical substitution or misplaced trust in the visible context.	User Organization Service provider	- Inspect the code for overlays or tampering - Confirm source legitimacy - Protect operational QR codes with labels and routine inspection
Post-scan / pre-navigation	Destination opacity, shortened links, unrelated or obfuscated domains.	User QR reader Browser interface	- Preview the full URL - Compare the registered domain with the expected service - Require explicit confirmation before opening
Destination page interaction	Fraudulent request for credentials, payment, personal data, or application installation.	User Platform Service provider	- Do not submit sensitive information unless the request is expected and independently verifiable - Use the official app or manually entered address
Transaction or submission	Completion of an unauthorized action under deceptive but plausible conditions.	User Platform Payment or authentication system	- Display recipient, amount, or intended action before authorization - Support signed or otherwise verifiable QR codes and transaction confirmation
Post-exposure response	Credential compromise, payment fraud, malware delivery, or exposure of sensitive information.	User Organization Security team	- Report the incident - Change credentials and revoke active sessions - Monitor accounts - Preserve evidence - Initiate response procedures

Figure 5. Literature-derived conceptual mapping of quishing stages, associated risks, responsible actors, and potential controls. The framework organizes plausible intervention points but has not been empirically validated as an integrated security intervention.

Table 2. Multi-level Decalogue of Protection against Quishing, classified by responsible actor, intervention timing, and normalized scope.

No.	Protective Control	Primary Actor	Timing	Scope
1	Verify the QR code source and physical integrity. Inspect placement, ownership cues, overlays, replacement stickers, and inconsistencies with the surrounding context.	User/organization	Before scanning	QR-specific
2	Secure institutional QR-code deployment. Publish codes through authenticated channels and maintain inventories, anti-tamper measures, periodic inspection, and rapid replacement procedures.	Organization	Before scanning	QR-specific
3	Preview the destination before navigation. Use scanners or applications that display the decoded destination and require explicit confirmation before opening it.	Interface/platform	After decoding	QR-specific
4	Validate the destination. Inspect the complete domain, subdomains, Punycode, redirects, and shortened URLs before opening the destination.	User/interface	Before navigation	QR-specific + defense-in-depth

Table 2. Cont.

No.	Protective Control	Primary Actor	Timing	Scope
5	Use an independent route for sensitive services. Open the official application or manually enter the address when the QR code is unexpected or the requested action is consequential.	User	Before login or payment	QR-specific
6	Treat unexpected sensitive requests as high-risk signals. Stop when the destination requests credentials, payment, application installation, permissions, or authentication approval.	User/interface	At destination	QR-specific + defense-in-depth
7	Strengthen authentication and transaction verification. Use phishing-resistant multi-factor authentication (MFA) or passkeys and independently verify transaction or login prompts.	User/organization	Authentication or payment	Defense-in-depth
8	Apply layered technical detection. Use URL reputation checks, multimodal QR-code and landing-page analysis, WebView inspection, sandboxing, and network filtering where operationally appropriate.	Platform/security team	Before or during access	QR-specific + defense-in-depth
9	Provide usable warnings and reporting mechanisms. Display concise contextual and destination information and offer accessible reporting options throughout the interaction.	Interface/organization	Throughout interaction	QR-specific
10	Respond promptly after suspected exposure. Close the session, report the code, preserve relevant evidence, revoke active sessions, change affected credentials, and contact the institution.	User/organization	After exposure	Defense-in-depth

Note: QR-specific controls address properties of QR-mediated interaction. Defense-in-depth controls are broader safeguards applicable across phishing, authentication, technical protection, or incident-response contexts. The combined label is used only when a measure operates at both levels.

4. Discussion

The evidence synthesized in this study indicates that quishing is best understood as a phishing process whose effectiveness emerges from the interaction of QR-specific technical properties, contextual legitimacy, user decision-making, and the design of verification mechanisms. The principal contribution of the proposed framework is therefore not a new detection algorithm or a predictive behavioral model. Rather, it provides a cross-level interpretation of where the attack gains credibility and where responsibility for prevention can be distributed among users, interfaces, organizations, platforms, and security infrastructure.

4.1. Interpretation of the Main Findings

The predominance of technical studies in the corpus shows that quishing research has concentrated mainly on detecting malicious QR symbols, encoded URLs, landing pages, or related network behavior. Machine learning, deep learning, structural analysis, multimodal, cryptographic, blockchain, and network-level proposals expand the available defensive repertoire [14–20]. However, the limited number of direct user studies means that technical performance should not be treated as equivalent to demonstrated protection in realistic interaction conditions. A classifier may identify a suspicious destination after decoding, yet the practical benefit depends on when the result is shown, whether the warning is understandable, and whether the application allows the user to interrupt the interaction.

The synthesis also clarifies the function of the sociotechnical triad. Contextual trust, routine scanning, and constrained verification should not be interpreted as three independent causal variables. They describe a plausible reinforcement sequence: a legitimate-looking environment can lower initial suspicion; reduced suspicion can favor rapid or habitual scanning; and the opacity of the encoded destination can postpone meaningful inspection until the user has already entered a mobile browser, payment flow, or authentication interface. This interpretation is consistent with empirical work showing that phishing succeeds when deceptive cues are processed under limited attention or through familiar social contexts [22–24]. Nevertheless, because most QR-specific studies did not manipulate these variables experimentally, the proposed sequence remains a literature-derived explanation rather than a validated causal pathway.

4.2. Quishing-Specific Risk vs. General Phishing Mechanisms

The results support a clear distinction between the properties specific to QR-mediated attacks and the deceptive mechanisms inherited from conventional phishing. These QR-specific mechanisms include destination opacity before decoding, the possibility of sticker overlay or code replacement [51], cross-device transitions, and mobile interfaces that constrain domain inspection. The QR code also functions as a bridge between physical and digital environments, allowing trust associated with a physical object or service context to transfer to the encoded destination. Together, these properties affect the timing, visibility, and usability of verification. By contrast, impersonation, familiar branding, authority cues, urgency, fraudulent login pages, payment manipulation, and malicious downloads are not exclusive to quishing [8,9,11–13]. They generally operate after the QR code has transported the user to an attacker-controlled resource.

This distinction matters for both novelty and mitigation. Quishing should not be presented as wholly separate from phishing because its downstream deception frequently relies on established social-engineering techniques. Its distinctive role in the attack lies in concealing the destination, embedding access within an apparently legitimate physical or service context, and disclosing the destination through a mobile interaction that may provide fewer usable verification cues. Consequently, controls designed only for suspicious email links may fail to address malicious printed codes, payment prompts, posters, invoices, or QR images embedded in attachments.

4.3. Human Factors, Cognitive Biases, and Existing Behavioral Models

The broader phishing and usable-security literature offers a useful interpretive basis for the behavioral patterns observed in the QR-specific corpus. Vishwanath et al. explain phishing vulnerability through differences in information processing, attention, prior knowledge, and habitual media use [24]. The present framework is compatible with that model but emphasizes additional channel-specific conditions: users cannot visually inspect the encoded destination before decoding, the surrounding physical context can transfer legitimacy to

the code, and the mobile interface can constrain subsequent inspection. The proposed sociotechnical model therefore complements an individual-level information-processing explanation by making the QR artifact, the surrounding context, and the verification interface explicit components of the interaction.

The findings are also consistent with the usable-security argument that security failures should not be attributed exclusively to an allegedly careless user [25]. When an application opens a decoded destination automatically, truncates the registered domain, provides generic warnings, or fails to distinguish an expected transaction from an unexpected request, the system shifts an unrealistic verification burden to the individual. The revised protection matrix consequently assigns responsibilities not only to users but also to QR publishers, interface designers, browser and platform providers, and organizational security teams.

Several cognitive biases may help explain why a malicious QR code appears acceptable: authority bias when the code seems associated with an institution; familiarity and normality biases when scanning is routine; social proof when others appear to use the same code; urgency when immediate payment or authentication is requested; optimism bias when the user assumes that compromise is unlikely; and habituation when repeated benign scanning reduces attention. These concepts are relevant to the attack sequence, but they were not consistently measured in the primary quishing studies. They should therefore be treated as theoretically informed interpretations that require direct testing, not as established prevalence estimates or proven determinants of victimization.

Prior phishing interventions demonstrate that training and contextual education can improve recognition, particularly when learning is embedded in realistic tasks [28]. For quishing, however, awareness alone is unlikely to be sufficient. Users cannot verify information that the interface does not expose, and repeated warnings can lose salience through habituation. Behavioral support should therefore be combined with usable destination previews, domain-focused warnings, delayed navigation, independent routes to sensitive services, and readily accessible reporting mechanisms.

These recommendations are also consistent with research on security-warning design, which treats warnings as decision-support mechanisms rather than as substitutes for user vigilance. Zaaba et al. synthesized recurring barriers to effective security warnings, including limited attention, technical terminology, insufficient information, and habituation, and reviewed design approaches intended to improve warning salience and comprehension [52]. More recent phishing-warning research indicates that message content, placement, level of friction, and timing may influence user agency, trust, risk interpretation, and the actions that follow a warning [53]. In the quishing context, destination previews, domain-focused contextual warnings, delayed navigation, and accessible reporting mechanisms can therefore be interpreted as user-centered design elements intended to interrupt automatic scanning and expose the information required for an informed decision. Their effectiveness in QR-mediated interactions, however, remains to be empirically tested.

Behaviorally informed interventions also provide a basis for evaluating these design elements as nudges rather than as guarantees of protection. A large field experiment found that just-in-time feedback following simulated phishing exposure reduced susceptibility to a subsequent phishing message and, for some participants, increased reporting behavior [54]. At the organizational level, recent cybersecurity-awareness research argues that knowledge gains should be connected to persuasive, achievable, and continuously reinforced behaviors [55], while reviews of awareness-assessment scales identify recurring weaknesses in construct definition, scale development, and validity evidence [56]. A behavioral cybersecurity strategy should therefore include a feedback loop that measures both intervention usability and observable security behavior [57]. Accordingly, future validation

of the proposed quishing interventions should combine validated awareness measures with behavioral outcomes such as destination inspection, independent navigation, continuation or abandonment, reporting, and credential or payment submission.

4.4. Implications for Layered Mitigation

The main practical implication is that quishing mitigation requires layered controls aligned with the stages of QR-code interaction and distributed among users, organizations, interfaces, platforms, and security teams. Before scanning, QR-specific organizational controls can reduce physical substitution through authenticated publication channels, QR-code inventories, visible ownership indicators, tamper-resistant placement, periodic inspection, and rapid replacement procedures. After decoding, QR-specific interface controls should display the complete destination without navigating automatically and visually emphasize the registered domain within the full URL. At the destination, combined QR-specific and defense-in-depth controls should flag pages that make unexpected requests for credentials, payment, application installation, permissions, or authentication approval, while directing users to verify the request independently or access the service through its official application or a manually entered address. Neither HTTPS nor certificate validity should be treated as proof that the destination is legitimate. Broader defense-in-depth measures, including phishing-resistant authentication, reporting mechanisms, session revocation, credential changes, account monitoring, and evidence preservation, can reduce the consequences of suspected exposure.

The technical approaches identified in the corpus remain important, but their coverage is partial. Structural or image-based methods may detect altered codes without establishing whether the destination is malicious. URL-based systems operate only after decoding and may be challenged by redirects, shortening services, compromised legitimate domains, or rapidly changing infrastructure. Cryptographic, tokenized, or blockchain-supported approaches can strengthen authenticity, but they depend on key management, governance, interoperability, and adoption. Network and WebView analysis can provide additional inspection, although operational latency, privacy, false positives, and platform compatibility require evaluation. These limitations favor defense in depth rather than reliance on a single control family.

The revised Decalogue should accordingly be interpreted as a multi-level allocation of protective responsibilities rather than as a guarantee that individual vigilance will prevent attacks. Items concerning source inspection, destination preview, and independent navigation are closely tied to QR-mediated risk. Multi-factor authentication, software updates, browser protections, and endpoint security are broader controls that may reduce consequences after malicious navigation; they should not be represented as QR-specific prevention. This separation improves the traceability between the identified mechanism and the proposed intervention.

4.5. Limitations and Future Validation

This study has several limitations. First, the study is limited by the scope of the literature-identification strategy and by the availability of full-text publications during the review period. Bibliographic records were subsequently verified through sources including IEEE Xplore, arXiv, Crossref, publisher platforms, conference proceedings, and institutional repositories. Accordingly, the review should not be considered exhaustive. Second, eligibility was limited to English- and Spanish-language publications from 2010 to 2026. Third, the corpus was heterogeneous in study design, datasets, samples, validation procedures, and reported outcomes, which prevented quantitative pooling or direct comparisons of effectiveness. Fourth, five included studies were preprints at the search

cutoff date, and several technical proposals relied on synthetic or study-specific datasets with limited external validation.

The behavioral evidence was especially limited. Only five studies primarily examined susceptibility, awareness, security behavior, or naturalistic interaction, and most did not directly measure the cognitive biases used to interpret the findings. The proposed attack sequence, sociotechnical model, decision flow, integrated framework, and protection recommendations were derived from the narrative synthesis and were not empirically evaluated as a combined intervention. They should therefore be regarded as heuristic artifacts that organize the available evidence and define testable propositions.

A proportionate validation program could proceed in three stages. First, a multidisciplinary expert review could assess content validity, completeness, and the correspondence between each identified risk and proposed control. Second, usability walkthroughs and controlled experiments could compare a baseline QR-code scanner with interfaces that provide destination previews, registered-domain emphasis, contextual warnings, and delayed navigation. Observable outcomes should include scanning behavior, URL inspection, independent navigation, continuation or abandonment, credential or payment submission, application-installation attempts, reporting behavior, task-completion time, warning comprehension, and false-alarm effects. Third, naturalistic and longitudinal studies could determine whether safer behaviors are maintained after repeated exposure and whether warning effectiveness declines through habituation. Such evaluation would establish which components are usable, which influence behavior, and which reduce harmful outcomes without imposing excessive friction.

4.6. Overall Interpretation

Taken together, the findings support a layered sociotechnical interpretation of quishing. QR codes create a distinctive verification problem by concealing and transporting a destination across physical, digital, and mobile contexts, while the subsequent deception frequently relies on mechanisms already known from phishing. Technical detection, usable interfaces, organizational control of published codes, user decision support, and post-exposure safeguards address different parts of this process. The proposed framework makes these relationships explicit, but its practical value must be established through empirical validation rather than assumed from conceptual coherence alone.

5. Conclusions

This study examined quishing through a structured, targeted review of 27 QR-code-phishing publications and a narrative thematic synthesis. The evidence base was dominated by technical detection, verification, and prevention proposals, while direct behavioral and naturalistic studies remained comparatively limited. This imbalance indicates that the technical mechanisms of quishing are developing more rapidly than evidence concerning how users interpret warnings, verify destinations, and respond under realistic conditions.

The synthesis supports treating quishing as a QR-mediated form of phishing with several channel-specific characteristics. These include concealment of the destination before decoding, transfer of trust from a physical or digital context to the encoded resource, the possibility of code replacement or overlay, cross-channel transition to a mobile device, and constrained visibility of destination information. After navigation, however, attackers frequently rely on mechanisms shared with conventional phishing, including impersonation, urgency, deceptive login or payment interfaces, and requests for credentials, personal information, software installation, or authorization.

The principal contribution of this study is a literature-derived integration of these mechanisms into an operational attack sequence, a sociotechnical model, a heuristic user

decision flow, and a multi-level protection framework. Together, these outputs identify potential interruption points before scanning, after decoding, during navigation, at the destination, and after suspected exposure. They also distribute protective responsibility across users, interface and platform designers, organizations, service providers, and security teams rather than assigning prevention exclusively to the individual who scans the code.

The proposed models and recommendations are conceptual artifacts, not predictive models or empirically validated guarantees of risk reduction. Their practical value should therefore be assessed through expert review, usability walkthroughs, controlled experiments, and naturalistic or longitudinal studies. Relevant outcomes include destination inspection, independent navigation, continuation or abandonment of the interaction, credential or payment submission, installation attempts, reporting behavior, warning comprehension, false-alarm effects, and the persistence of safer behavior over time.

The study is limited by the scope of the literature-identification strategy and by the availability of full-text publications during the review period, the inclusion of five preprints, methodological heterogeneity, and the relatively small behavioral evidence base. Within these limitations, the findings indicate that no single technical or educational measure is sufficient. A defensible mitigation strategy requires layered controls that combine QR-specific safeguards—such as authenticated placement, destination preview, domain-focused verification, and transaction confirmation—with broader defense-in-depth and incident-response measures. Future empirical evaluation should determine which combinations provide meaningful protection without imposing excessive friction on legitimate QR-code use.

Supplementary Materials: The following supporting information can be downloaded at <https://www.mdpi.com/article/10.3390/jcp6040134/s1>, File S1: Bibliographic records, study-selection decisions, data-extraction matrix, methodological-quality appraisal, PRISMA counts, and traceability map.

Author Contributions: Conceptualization, P.-D.F.-A. and R.M.-M.; methodology, P.-D.F.-A.; validation, P.-D.F.-A. and L.L.-G.; formal analysis, P.-D.F.-A. and L.L.-G.; investigation, P.-D.F.-A. and L.L.-G.; data curation, P.-D.F.-A. and L.L.-G.; visualization, L.L.-G.; writing—original draft preparation, P.-D.F.-A.; writing—review and editing, P.-D.F.-A., R.M.-M. and L.L.-G.; supervision, L.L.-G.; project administration, R.M.-M. All authors have read and agreed to the published version of the manuscript.

Funding: This research received no external funding.

Institutional Review Board Statement: Not applicable.

Informed Consent Statement: Not applicable.

Data Availability Statement: The data supporting the findings of this study are included within the article and Supplementary File S1, which contains the bibliographic records, study-selection decisions, data-extraction matrix, methodological-quality appraisal, PRISMA counts, and a traceability map linking manuscript-level quantitative statements and study-level records. No new human-participant, experimental, or proprietary datasets were generated. Further inquiries may be directed to the corresponding author.

Acknowledgments: During the preparation of this manuscript, the authors used ChatGPT (GPT-5; OpenAI, San Francisco, CA, USA; accessed in July 2026) to support English-language editing and the preliminary conceptual organization of selected figures. All AI-assisted outputs were critically reviewed, verified, and revised by the authors, who take full responsibility for the accuracy, originality, and integrity of the final manuscript. The authors also acknowledge the Secretaría de Ciencia, Humanidades, Tecnología e Innovación (SECIHTI), Mexico, and the recognition granted through the Sistema Nacional de Investigadoras e Investigadores (SNII) for supporting and promoting their academic and research activities.

Conflicts of Interest: The authors declare no conflicts of interest.

Abbreviations

The following abbreviations are used in this manuscript:

AI	Artificial Intelligence
BiTB	Browser-in-the-Browser
CSV	Comma-Separated Values
DOI	Digital Object Identifier
HMAC	Hash-Based Message Authentication Code
HTTPS	Hypertext Transfer Protocol Secure
MFA	Multi-Factor Authentication
PRISMA	Preferred Reporting Items for Systematic Reviews and Meta-Analyses
PRISMA-ScR	PRISMA Extension for Scoping Reviews
PRISMA-S	PRISMA Extension for Literature Searches
QR	Quick Response
URL	Uniform Resource Locator

References

1. Yan, L.-Y.; Tan, G.W.-H.; Loh, X.-M.; Hew, J.-J.; Ooi, K.-B. QR Code and Mobile Payment: The Disruptive Forces in Retail. *J. Retail. Consum. Serv.* **2021**, *58*, 102300. [\[CrossRef\]](#)
2. Rashid, M.; Zakir, S.; Zeb, J. QR Codes and Mobile Marketing: Advertising Strategies and Consumer Intentions in Developing Economies. *Qlantic J. Soc. Sci. Humanit.* **2024**, *5*, 258–271. [\[CrossRef\]](#)
3. Lorenzi, D.; Vaidya, J.; Chun, S.; Shafiq, B.; Atluri, V. Enhancing the Government Service Experience through QR Codes on Mobile Platforms. *Gov. Inf. Q.* **2014**, *31*, 6–16. [\[CrossRef\]](#)
4. Rotsios, K.; Konstantoglou, A.; Folinas, D.; Fotiadis, T.; Hatzithomas, L.; Boutsouki, C. Evaluating the Use of QR Codes on Food Products. *Sustainability* **2022**, *14*, 4437. [\[CrossRef\]](#)
5. Ozturkcan, S.; Kitapci, O. A Sustainable Solution for the Hospitality Industry: The QR Code Menus. *J. Inf. Technol. Teach. Cases* **2025**, *15*, 2–7. [\[CrossRef\]](#)
6. Sondhi, A.; Kumar, R. QR Codes in Education: A Review. *Int. J. Sci. Res. Sci. Technol.* **2022**, *9*, 193–205. [\[CrossRef\]](#)
7. Masih, E.A. Feasibility of Using QR Code for Registration and Evaluation of Training and Its Ability to Increase Response Rate—The Learners' Perception. *Nurse Educ. Today* **2022**, *111*, 105305. [\[CrossRef\]](#) [\[PubMed\]](#)
8. Vidas, T.; Owusu, E.; Wang, S.; Zeng, C.; Cranor, L.F.; Christin, N. QRishing: The Susceptibility of Smartphone Users to QR Code Phishing Attacks. In *Financial Cryptography and Data Security, Proceedings of the FC 2013 Workshops, Okinawa, Japan, 1 April 2013*; Adams, A.A., Brenner, M., Smith, M., Eds.; Springer: Berlin/Heidelberg, Germany, 2013; Volume 7862, pp. 52–69. [\[CrossRef\]](#)
9. Sharevski, F.; Devine, A.; Pieroni, E.; Jachim, P. Phishing with Malicious QR Codes. In *Proceedings of the European Symposium on Usable Security (EuroUSEC 2022), Karlsruhe, Germany, 29–30 September 2022*; Association for Computing Machinery: New York, NY, USA, 2022; pp. 160–171. [\[CrossRef\]](#)
10. Pricop, E.; Mihalache, S.F. Quishing—A Review of QR Code Attacks and a Framework Design for Safe Scanning. In *Proceedings of Fifth Emerging Trends and Technologies on Intelligent Systems (ETTIS 2025), Noida, India, 19–21 March 2025*; Pricop, E., Saroha, K., Sen, A., Trivedi, G., Johari, K., Eds.; Springer: Singapore, 2026; Volume 1591, pp. 284–296. [\[CrossRef\]](#)
11. Akram, M.W.; Sood, K.; Ul Hassan, M.; Subba, B. Exemplifying Emerging Phishing: QR-Based Browser-in-the-Browser (BiTB) Attack. *IEEE Netw. Lett.* **2025**, *7*, 274–278. [\[CrossRef\]](#)
12. Amoah, G.A.; Hayfron-Acquah, J.B. QR Code Security: Mitigating the Issue of Quishing (QR Code Phishing). *Int. J. Comput. Appl.* **2022**, *184*, 34–39. [\[CrossRef\]](#)
13. Geisler, M.; Pöhn, D. Hooked: A Real-World Study on QR Code Phishing. *arXiv* **2024**, arXiv:2407.16230. [\[CrossRef\]](#)
14. Akram, M.W.; Sood, K.; Ul Hassan, M. QRiS: A Preemptive Novel Method for Quishing Detection through Structural Features of QR. *arXiv* **2025**, arXiv:2510.17175. [\[CrossRef\]](#)
15. Sarkhi, M.; Mishra, S. Detection of QR Code-Based Cyberattacks Using a Lightweight Deep Learning Model. *Eng. Technol. Appl. Sci. Res.* **2024**, *14*, 15209–15216. [\[CrossRef\]](#)
16. Alsulami, A.A.; Abu Al-Haija, Q.; Alturki, B.; Yafoz, A.; Alqahtani, A.; Alsini, R.; Binyamin, S.S. Efficient Malicious QR Code Detection System Using an Advanced Deep Learning Approach. *Comput. Model. Eng. Sci.* **2025**, *145*, 1117–1140. [\[CrossRef\]](#)
17. Trad, F.; Chehab, A. Detecting Quishing Attacks with Machine Learning Techniques through QR Code Analysis. *arXiv* **2025**, arXiv:2505.03451. [\[CrossRef\]](#)
18. Yalda, R.; Khan, A.; Nepal, N. B-PhishQR—A Blockchain-Based Framework for Secure QR Code Verification against Phishing Attacks. *Telemat. Inform. Rep.* **2026**, *21*, 100289. [\[CrossRef\]](#)

19. Mukhammedali, Z.; Khan, V.; Razaque, A.; Khan, M.A.; Kalpeyeva, Z. AI-Enhanced Security Framework for QR Codes. In *Proceedings of the 2025 1st International Conference on Secure IoT, Assured and Trusted Computing (SATC), Dayton, OH, USA, February 2025*; IEEE: Piscataway, NJ, USA, 2025; pp. 1–5. [\[CrossRef\]](#)
20. Akram, M.W.; Sood, K.; Ul Hassan, M.; Thiruvady, D. ALFA: A Safe-by-Design Approach to Mitigate Quishing Attacks Launched via Fancy QR Codes. *arXiv* **2026**, arXiv:2601.06768. [\[CrossRef\]](#)
21. Singkeruang, A.W.T.F.; Susanto, S.E.; Saeni, N. Mitigating the Risk of Quishing Threats (QR Phishing) Using the Security Behavior Intentions Scale (SeBIS) in Supporting Digital Economic Security. *Parad. J. Ilmu Ekon.* **2025**, *8*, 685–696. [\[CrossRef\]](#)
22. Dhamija, R.; Tygar, J.D.; Hearst, M.A. Why Phishing Works. In *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems (CHI 2006), Montréal, QC, Canada, 22–27 April 2006*; Association for Computing Machinery: New York, NY, USA, 2006; pp. 581–590. [\[CrossRef\]](#)
23. Jagatic, T.N.; Johnson, N.A.; Jakobsson, M.; Menczer, F. Social Phishing. *Commun. ACM* **2007**, *50*, 94–100. [\[CrossRef\]](#)
24. Vishwanath, A.; Herath, T.; Chen, R.; Wang, J.; Rao, H.R. Why Do People Get Phished? Testing Individual Differences in Phishing Vulnerability within an Integrated Information Processing Model. *Decis. Support Syst.* **2011**, *51*, 576–586. [\[CrossRef\]](#)
25. Sasse, M.A.; Brostoff, S.; Weirich, D. Transforming the ‘Weakest Link’—A Human/Computer Interaction Approach to Usable and Effective Security. *BT Technol. J.* **2001**, *19*, 122–131. [\[CrossRef\]](#)
26. Tricco, A.C.; Lillie, E.; Zarin, W.; O’Brien, K.K.; Colquhoun, H.; Levac, D.; Moher, D.; Peters, M.D.J.; Horsley, T.; Weeks, L.; et al. PRISMA Extension for Scoping Reviews (PRISMA-ScR): Checklist and Explanation. *Ann. Intern. Med.* **2018**, *169*, 467–473. [\[CrossRef\]](#) [\[PubMed\]](#)
27. Rethlefsen, M.L.; Kirtley, S.; Waffenschmidt, S.; Ayala, A.P.; Moher, D.; Page, M.J.; Koffel, J.B.; PRISMA-S Group. PRISMA-S: An Extension to the PRISMA Statement for Reporting Literature Searches in Systematic Reviews. *Syst. Rev.* **2021**, *10*, 39. [\[CrossRef\]](#) [\[PubMed\]](#)
28. Kumaraguru, P.; Sheng, S.; Acquisti, A.; Cranor, L.F.; Hong, J.I. Teaching Johnny Not to Fall for Phish. *ACM Trans. Internet Technol.* **2010**, *10*, 1–31. [\[CrossRef\]](#)
29. Vishwanath, A.; Harrison, B.; Ng, Y.J. Suspicion, Cognition, and Automaticity Model of Phishing Susceptibility. *Commun. Res.* **2018**, *45*, 1146–1166. [\[CrossRef\]](#)
30. Iuga, C.; Nurse, J.R.C.; Erola, A. Baiting the Hook: Factors Impacting Susceptibility to Phishing Attacks. *Hum.-Centric Comput. Inf. Sci.* **2016**, *6*, 8. [\[CrossRef\]](#)
31. Salahdine, F.; Kaabouch, N. Social Engineering Attacks: A Survey. *Future Internet* **2019**, *11*, 89. [\[CrossRef\]](#)
32. Nigam, N.; Bhandari, R. A Network-Level Prevention Framework for Real-Time QR Code Phishing Attack Mitigation. *Int. J. Comput. Inf. Syst. Ind. Manag. Appl.* **2026**, *18*, 737–757. [\[CrossRef\]](#)
33. Kritika, M. A Systematic Literature Review on Deep Learning Approaches for QR Code-Based Phishing (Quishing) Detection: Emerging Attack Vectors, Multimodal Feature Fusion and Open Research Challenges. *J. Cyber Secur. Technol.* **2026**, *10*, 2696261. [\[CrossRef\]](#)
34. Nejati, F.; Rabbani, M.; Mirani, M.; Piya, G.; Opushnyev, I.; Ghorbani, A.A.; Dadkhah, S. CIC-Trap4Phish: A Unified Multi-Format Dataset for Phishing and Quishing Attachment Detection. *arXiv* **2026**, arXiv:2602.09015. [\[CrossRef\]](#)
35. Yuniati, S.E.; Widjajarto, A.; Hediyanto, U.Y.K.S. Implementation and Analysis of QR Code Phishing Attacks on Indonesian Internet Banking Using Attack Tree and Time-Based Metrics. *J. Tek. Inform.* **2026**, *7*, 44–59. [\[CrossRef\]](#)
36. Tian, Y.; Zhu, E. Incremental Phishing Defense Method Based on QR Code Decoding and Multimodal Deep Learning. In *Proceedings of the 2026 5th International Conference on Cryptography, Network Security and Communication Technology (CNSCT 2026), Haikou, China, 23–25 January 2026*; Association for Computing Machinery: New York, NY, USA, 2026; pp. 209–214. [\[CrossRef\]](#)
37. Mashaleh, A.S.; Al-Hamadeen, H.M.; Gawanmeh, A. QRphish: An Automated QR Code Phishing Detection Approach. In *Proceedings of the 2026 2nd International Conference on Computational Intelligence Approaches and Applications (ICCIAA), Amman, Jordan, 12–14 May 2026*; IEEE: Piscataway, NJ, USA, 2026; pp. 1–6. [\[CrossRef\]](#)
38. Shashank, S.K.; Hegde, R.; Hegde, S.K. Quishing Detection in UPI Platform Using Machine Learning. In *Proceedings of the 2026 Second International Conference on Multi-Agent Systems for Collaborative Intelligence (ICMSCI), Erode, India, 2–4 March 2026*; IEEE: Piscataway, NJ, USA, 2026; pp. 385–391. [\[CrossRef\]](#)
39. Woo, J.; Lee, S.; Park, I.; Lee, S. WebView-Based Hybrid Analysis of Link and Event for On-Device QR Phishing Detection Framework. *Sensors* **2026**, *26*, 4412. [\[CrossRef\]](#) [\[PubMed\]](#)
40. Okewale, O.A.; Olajide, T.D.; Salifu, H.K.; Oguntunde, S.; Benedict, S.O.; Fatoki, S.K.; Oluwaseun, S.S.; Osadolor, M.D. Blockchain-Based Framework for Mitigating QR Code Phishing Attacks in Financial Systems. *J. Syst. Mod. Sci. Res.* **2026**, *10*, 92–120. [\[CrossRef\]](#)
41. Khalifa, O.Y.I.; Muhammad Zaly Shah, M.Z. MultiPhishNet: A Multimodal Approach of QR Code Phishing Detection Using Multi-Head Attention and Multilingual Embeddings. *Int. J. Innov. Comput.* **2025**, *15*, 53–61. [\[CrossRef\]](#)

42. Maretmy, A.; Maulina, R.; Nisa, Z.; Hapsari, E.T.; Yanti, H. QR Code Payment Security against Phishing Attacks Using HMAC Cryptographic Model and Tokenization. *Install Inf. Syst. Technol. J.* **2025**, *2*, 24–34. Available online: <https://ejurnal.unism.ac.id/index.php/install/article/view/997> (accessed on 21 July 2026).
43. Blancaflor, E.; Algabre, M.; Angeles, C.J.; Goc-Ong, A.; Liberato, E.K.; Ladera, L.; Rey, W.P. Simulating QR Code Scanner Phishing Attacks: Investigating Vulnerabilities in QR Scanning and Reading Mechanisms Leading to Cookie and Data Exposure in Organization Environment. In *Proceedings of the 2025 7th World Symposium on Software Engineering (WSSE 2025)*, Okayama, Japan, 24–26 October 2025; Association for Computing Machinery: New York, NY, USA, 2026; pp. 157–163. [\[CrossRef\]](#)
44. Sharevski, F.; Mossano, M.; Veit, M.F.; Schiefer, G.; Volkamer, M. Exploring Phishing Threats through QR Codes in Naturalistic Settings. In *Proceedings of the Symposium on Usable Security and Privacy (USEC 2024)*, San Diego, CA, USA, 26 February–1 March 2024; Internet Society: Reston, VA, USA, 2024. [\[CrossRef\]](#)
45. Durga, C.B.V.; Maddi, L.S.K.; Teki, V.M.; Padamata, U.; Vankamamidi, S.S.R. Hybrid Advanced Encryption Mechanism to Generate Visual QR Code for Preventing Phishing Attacks. *Decis. Mak. Appl. Manag. Eng.* **2024**, *7*, 452–462. Available online: <https://dmame-journals.org/index.php/dmame/article/download/85/90> (accessed on 21 July 2026).
46. Taraka Rama Mokshagna Teja, M.; Praveen, K. Prevention of Phishing Attacks Using QR Code Safe Authentication. In *Inventive Computation and Information Technologies*; Smys, S., Balas, V.E., Palanisamy, R., Eds.; Springer: Singapore, 2022; Volume 336, pp. 361–372. [\[CrossRef\]](#)
47. Yong, K.S.C.; Chiew, K.L.; Tan, C.C.L. A Survey of the QR Code Phishing: The Current Attacks and Countermeasures. In *Proceedings of the 2019 7th International Conference on Smart Computing & Communications (ICSCC)*, Sarawak, Malaysia, 28–30 June 2019; IEEE: Piscataway, NJ, USA, 2019; pp. 1–5. [\[CrossRef\]](#)
48. Mavroeidis, V.; Nicho, M. Quick Response Code Secure: A Cryptographically Secure Anti-Phishing Tool for QR Code Attacks. In *Computer Network Security, Proceedings of MMM-ACNS 2017, Warsaw, Poland, 28–30 August 2017*; Rak, J., Bay, J., Kutenko, I., Popyack, L., Skormin, V., Szczypiorski, K., Eds.; Springer: Cham, Switzerland, 2017; Volume 10446, pp. 313–324. [\[CrossRef\]](#)
49. Dayaratne, T.T. A Framework to Prevent QR Code Based Phishing Attacks. *arXiv* **2016**, arXiv:1602.00067. [\[CrossRef\]](#)
50. Alnajjar, A.Y.; Manickam, S.; Anbar, M.; Al-Saleem, S.; Elejla, O. TrustQR: A New Technique for the Detection of Phishing Attacks on QR Code. *Adv. Sci. Lett.* **2016**, *22*, 2905–2909. [\[CrossRef\]](#)
51. Kharraz, A.; Kirda, E.; Robertson, W.; Balzarotti, D.; Francillon, A. Optical Delusions: A Study of Malicious QR Codes in the Wild. In *Proceedings of the 44th Annual IEEE/IFIP International Conference on Dependable Systems and Networks (DSN)*, Atlanta, GA, USA, 23–26 June 2014; IEEE: Piscataway, NJ, USA, 2014; pp. 192–203. [\[CrossRef\]](#)
52. Zaaba, Z.F.; Lim Xin Yi, C.; Amran, A.; Omar, M.A. Harnessing the Challenges and Solutions to Improve Security Warnings: A Review. *Sensors* **2021**, *21*, 7313. [\[CrossRef\]](#) [\[PubMed\]](#)
53. Pham, S.; Lenzini, G.; Pöhn, D. How Johnny Experiences Phishing Warnings: A Qualitative Study Investigating the Impact of Design Decisions on the User. *IEEE Access* **2025**, *13*, 211960–211980. [\[CrossRef\]](#)
54. Bender, S.; Horn, S.; Loewenstein, G.; Roberts, O. Phishing Feedback: Just-in-Time Intervention Improves Online Security. *Behav. Public Policy* **2026**, *10*, 527–539. [\[CrossRef\]](#)
55. Chaudhary, S. Driving Behaviour Change with Cybersecurity Awareness. *Comput. Secur.* **2024**, *142*, 103858. [\[CrossRef\]](#)
56. Rohan, R.; Pal, D.; Hautamäki, J.; Funilkul, S.; Chutimaskul, W.; Thapliyal, H. A Systematic Literature Review of Cybersecurity Scales Assessing Information Security Awareness. *Heliyon* **2023**, *9*, e14234. [\[CrossRef\]](#) [\[PubMed\]](#)
57. van Steen, T. Developing a Behavioural Cybersecurity Strategy: A Five-Step Approach for Organisations. *Comput. Stand. Interfaces* **2025**, *92*, 103939. [\[CrossRef\]](#)

Disclaimer/Publisher’s Note: The statements, opinions and data contained in all publications are solely those of the individual author(s) and contributor(s) and not of MDPI and/or the editor(s). MDPI and/or the editor(s) disclaim responsibility for any injury to people or property resulting from any ideas, methods, instructions or products referred to in the content.